NIS 2 et HDS : Comment les Nouvelles Réglementations Transforment Votre Stratégie de Sauvegarde et de Réponse

En 2025, deux cadres réglementaires majeurs imposent une refonte complète de la cybersécurité dans le secteur de la santé en France : la **Directive NIS 2** au niveau européen et la **certification HDS** à l'échelle nationale. Ce document analyse leurs exigences concrètes, leurs implications techniques et le plan d'action stratégique que les DSI, responsables cybersécurité et responsables conformité doivent mettre en œuvre pour garantir cyber-résilience et continuité des soins.

DSI & RESPONSABLES CONFORMITÉ | CYBERSÉCURITÉ SANTÉ | FRANCE · 2025

Le Contexte : Un Secteur de Santé Plus Connecté, Plus Vulnérable

La transformation numérique du secteur de la santé, accélérée par des plans ambitieux comme le **Ségur du numérique**, a profondément modernisé les établissements hospitaliers. Les Systèmes d'Information Hospitaliers (SIH) sont désormais au cœur de la prise en charge des patients, de la gestion des dossiers médicaux à la coordination des soins, en passant par la téléradiologie et la biologie connectée.

Cette hyperconnectivité, aussi bénéfique soit-elle, a considérablement élargi la surface d'attaque des cybercriminels. Les établissements de santé sont devenus des cibles prioritaires pour les attaques par rançongiciel, les intrusions de type APT (Advanced Persistent Threat) et les exfiltrations massives de données. En France, l'ANSSI recense régulièrement des incidents graves touchant des hôpitaux, certains ayant paralysé des établissements entiers pendant plusieurs semaines.

Face à cette menace systémique, les législateurs européens et français ont décidé de passer d'un cadre de recommandations à un cadre d'**obligations légales contraignantes**. NIS 2 et HDS incarnent cette transition : la conformité n'est plus une option, c'est une exigence opérationnelle dont le non-respect expose les établissements à des sanctions financières, administratives et réputationnelles majeures.

Pourquoi la santé est-elle une cible prioritaire ?

- Données à très haute valeur marchande sur le dark web
- Criticité vitale des systèmes : pression maximale pour payer
- Multiplicité des accès : personnels, prestataires, équipements médicaux connectés
- Retard historique dans les investissements cybersécurité
- Interdépendance forte entre établissements et fournisseurs tiers

La Directive NIS 2 : L'Impératif de la Résilience

La Directive NIS 2 constitue la pierre angulaire de la stratégie européenne de cybersécurité pour les secteurs critiques. En remplaçant la première directive NIS 1, elle introduit un niveau d'exigence inédit et un champ d'application considérablement élargi — qui concerne directement l'ensemble des acteurs de l'écosystème de santé français.

Entités Essentielles

Hôpitaux, CHU, centres hospitaliers régionaux — soumis aux obligations les plus strictes de NIS 2 avec contrôles ex ante.

Entités Importantes

Laboratoires, cliniques privées, éditeurs de logiciels de santé — soumis à des obligations proportionnées et à des contrôles ex post.

Fournisseurs Critiques

Prestataires cloud, intégrateurs SIH, hébergeurs — intégrés dans la chaîne de responsabilité via les obligations sur la supply chain.

L'ANSSI est l'autorité nationale compétente pour la transposition et le contrôle de NIS 2 en France. Elle dispose de pouvoirs d'audit, d'injonction et de sanction renforcés, ce qui confère à la directive une portée opérationnelle immédiate pour les DSI.

NIS 2 — A. Le Renforcement de la Gestion des Risques

Au cœur de NIS 2 se trouve une obligation de **gestion des risques proportionnée et documentée**. Les entités essentielles doivent prendre des mesures techniques, opérationnelles et organisationnelles appropriées pour gérer les risques pesant sur leurs réseaux et systèmes d'information. Pour la sauvegarde et la récupération, cette obligation se matérialise de façon très concrète.

Continuité d'Activité : PRA et PCA désormais obligatoires

Les établissements de santé doivent disposer d'une stratégie documentée et testée pour maintenir leurs services opérationnels ou les rétablir rapidement après un incident. Le **Plan de Reprise d'Activité (PRA)** et le **Plan de Continuité d'Activité (PCA)** ne sont plus de simples bonnes pratiques : ils constituent l'un des volets fondamentaux imposés par NIS 2. Ces plans doivent définir des objectifs mesurables de RTO (Recovery Time Objective) et de RPO (Recovery Point Objective) pour chaque système critique, notamment le SIH.

Sécurité de la Chaîne d'Approvisionnement

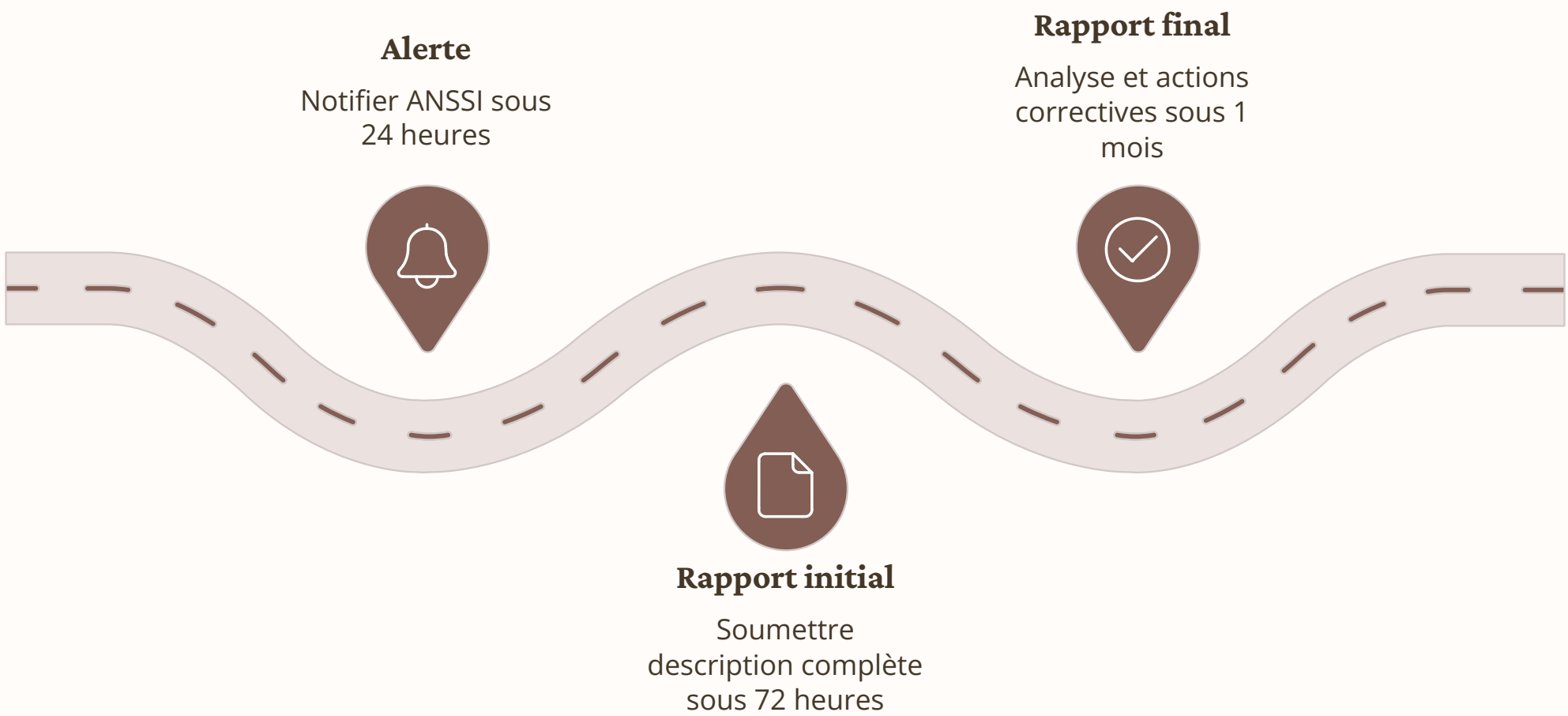
L'évaluation des risques ne peut plus se limiter au périmètre interne de l'établissement. Elle doit s'étendre à l'ensemble de l'écosystème numérique : fournisseurs de services cloud, intégrateurs, éditeurs de logiciels métier. L'ENISA insiste sur la nécessité de **valider contractuellement les garanties de cyber-résilience des tiers**, d'exiger des certifications reconnues et d'intégrer des clauses de sécurité dans les appels d'offres. Un fournisseur non conforme devient un vecteur de risque direct pour l'établissement.

Mesures Techniques Minimales Imposées

NIS 2 précise un socle de mesures qui comprend notamment : la gestion des identités et des accès, le chiffrement des données sensibles, la sécurité des communications, la gestion des correctifs et des vulnérabilités, et bien entendu les politiques et procédures de **sauvegarde, restauration et gestion de crise**. Ce socle devient la base de référence lors des audits de conformité.

NIS 2 — B. Les Obligations de Signalement Drastiques

L'une des innovations les plus contraignantes de NIS 2 pour les établissements de santé réside dans ses **délais de signalement extrêmement serrés**. Ces obligations redéfinissent le rôle de la sauvegarde et de la récupération : elles ne sont plus seulement des outils de continuité, elles deviennent des prérequis à la conformité légale lors d'un incident.



Dans le cas concret d'une attaque par rançongiciel — scénario malheureusement fréquent dans le secteur hospitalier — sans une solution de récupération rapide et opérationnelle, l'établissement se retrouve dans l'incapacité pratique de respecter ces délais. Submergé par le chaos opérationnel (systèmes inaccessibles, données chiffrées, urgences médicales à gérer), l'équipe IT ne peut produire un rapport initial cohérent dans les 72 heures que si elle dispose déjà de sauvegardes intègres et d'un processus de restauration fonctionnel. **La rapidité de la reprise d'activité devient ainsi un impératif direct de conformité légale**, et non plus seulement un objectif opérationnel.

> ⚠️ **Point de vigilance** : En cas de non-notification dans les délais, l'ANSSI peut prononcer des sanctions administratives incluant des amendes pouvant atteindre plusieurs millions d'euros, proportionnelles au chiffre d'affaires de l'entité. La direction générale est personnellement engagée dans cette responsabilité.

HDS : La Confiance et la Sécurité des Données au Niveau National

La certification **HDS (Hébergement de Données de Santé)** est le cadre de référence français qui garantit la sécurité et la confidentialité des données de santé à caractère personnel. Délivrée par des organismes accrédités et encadrée par le Code de la santé publique, elle s'impose à tout acteur qui héberge, maintient ou exploite des systèmes d'information contenant des données de santé.

Sécurité Physique et Logique

Les exigences HDS en matière de sécurité du système d'information sont particulièrement rigoureuses. Elles couvrent les mesures de **détection des incidents**, les mécanismes d'authentification forte, la gestion des habilitations et la traçabilité exhaustive des accès. Chaque opération sur les données de santé doit pouvoir être auditée, horodatée et attribuée à une identité vérifiée. Pour la sauvegarde, cela signifie que les journaux d'activité doivent eux-mêmes être sécurisés et conservés.

Localisation Obligatoire des Sauvegardes

Toute solution de sauvegarde cloud utilisée pour des données de santé doit impérativement s'appuyer sur un prestataire certifié HDS. Cette obligation s'applique y compris aux copies secondaires et aux sauvegardes hors site. La non-conformité expose l'établissement à des sanctions de la **CNIL**, qui peut prononcer des amendes, des injonctions de mise en conformité et des mises en demeure publiques.

Impact Direct sur la Stratégie de Sauvegarde des Hôpitaux

- **Choix des prestataires** : Vérification systématique de la certification HDS dans tout appel d'offres
- **Cartographie des flux** : Identification et documentation de tous les flux de données de santé sauvegardés
- **Cloisonnement** : Séparation entre données de santé et données administratives dans les politiques de sauvegarde
- **Traçabilité des restaurations** : Toute opération de restauration doit être journalisée et justifiable lors d'un audit
- **Durées de rétention** : Alignement sur les durées légales de conservation des données médicales

EHDS : La Brique Européenne qui Complète NIS 2 et HDS

Si NIS 2 et HDS constituent aujourd'hui les deux piliers réglementaires fondamentaux pour les établissements de santé français, il est essentiel d'anticiper dès maintenant l'arrivée du cadre **EHDS (Espace Européen des Données de Santé)**. Ce futur règlement européen s'appuie sur NIS 2, le RGPD et d'autres textes pour créer un espace sécurisé et harmonisé pour le partage et la protection des données de santé au sein de l'Union Européenne.

Interopérabilité Renforcée

Le EHDS introduit des obligations d'interopérabilité technique et sémantique pour les systèmes de santé. Les politiques de sauvegarde devront garantir que les données restaurées restent exploitables dans un contexte transfrontalier, avec des formats standardisés et des métadonnées préservées.

Contrôle d'Accès et Gouvernance

Le EHDS renforce les droits des patients sur leurs données et impose de nouveaux mécanismes de contrôle d'accès. Les systèmes de sauvegarde devront intégrer ces règles de gouvernance pour garantir que les données restaurées respectent les permissions en vigueur au moment de la récupération.

Harmonisation Européenne

En s'harmonisant avec le RGPD et NIS 2, le EHDS crée un cadre réglementaire unifié qui simplifiera à terme la conformité transfrontalière. Pour les DSI, préparer dès aujourd'hui la convergence NIS 2 / HDS facilitera l'intégration future du EHDS sans rupture stratégique majeure.

📌 **Anticipation stratégique** : Les DSI doivent préparer leur architecture technique non seulement à la convergence NIS 2 et HDS aujourd'hui, mais aussi à l'intégration future du EHDS. Les choix technologiques actuels — notamment en matière d'interopérabilité et de traçabilité des sauvegardes — doivent tenir compte de cette évolution européenne inéluctable.

De la Conformité à la Stratégie Technique : Le Plan d'Action

Pour aligner leur cybersécurité sur les exigences combinées de NIS 2 et HDS, les DSI doivent opérer une transformation profonde : passer d'une logique documentaire à une **véritable stratégie technique de cyber-résilience**. Trois axes structurants définissent ce plan d'action.

1

Le PSSI Intégrateur

La **Politique de Sécurité des Systèmes d'Information** doit être entièrement révisée pour intégrer les nouvelles contraintes réglementaires. Elle doit spécifier explicitement comment la fonction de sauvegarde et de récupération répond aux exigences de NIS 2 en matière de résilience et de signalement, et aux exigences HDS en matière de sécurité, de traçabilité et de localisation des données. Le PSSI devient le document de référence lors des audits de conformité.

2

L'Immuabilité comme Réponse Technique

Face à la menace des rançongiciels, l'**immuabilité des sauvegardes** est la réponse technique centrale. Il s'agit de la garantie logicielle ou matérielle qu'une sauvegarde ne peut être ni altérée, ni supprimée, ni chiffrée pendant une période définie. HDS exige la traçabilité et l'intégrité des données ; NIS 2 exige des RTO/RPO atteignables. Les deux convergent vers cette même solution technique.

3

L'Automatisation et les Tests Réguliers

L'ENISA et l'ANSSI insistent sur la **validation régulière et documentée** de la capacité de récupération. Les tests de PRA ne doivent plus être théoriques : ils doivent démontrer concrètement la capacité à rétablir les systèmes critiques dans les délais NIS 2. L'automatisation de la vérification d'intégrité et des processus de restauration réduit l'erreur humaine et garantit la vitesse de réponse.

L'Immuabilité : La Solution Technique aux Deux Défis Réglementaires

La menace du rançongiciel est le facteur de risque majeur que NIS 2 et HDS cherchent conjointement à atténuer. Les attaquants modernes ne se contentent plus de chiffrer les données primaires : ils ciblent systématiquement les **sauvegardes elles-mêmes**, sachant que leur destruction est la clé pour forcer le paiement de la rançon. L'immuabilité constitue la réponse technique incontournable à ce scénario.

L'Exigence HDS : Intégrité et Traçabilité

La certification HDS impose des mécanismes prouvant que les sauvegardes n'ont pas été modifiées depuis leur création. Seule l'immuabilité permet de fournir cette preuve cryptographique de non-altération, opposable lors d'un audit ou d'une investigation judiciaire. Sans cette garantie, la traçabilité exigée par HDS devient inatteignable en cas d'incident.

L'Exigence NIS 2 : RTO/RPO Garantis

L'objectif de rétablissement rapide défini dans le PRA ne peut être tenu que si les sauvegardes sont garanties propres et exploitables. Une sauvegarde compromise est une sauvegarde inutilisable, ce qui annule tout RTO prévu. L'immuabilité est donc la condition préalable à tout engagement contractuel ou réglementaire sur les délais de reprise.

Immuabilité Logicielle

Politiques WORM (Write Once Read Many) appliquées par le logiciel de sauvegarde, avec verrouillage temporel configurable.

Immuabilité Matérielle

Stockage sur support physique non réinscriptible (bandes LTO en mode WORM, baies de stockage avec verrou matériel).

Isolation et Air Gap

Copies isolées du réseau de production, déconnectées physiquement ou logiquement pour garantir l'inatteignabilité en cas d'attaque.

Vérification d'Intégrité

Contrôles cryptographiques automatiques (hash, empreintes) permettant de certifier l'intégrité de chaque sauvegarde avant toute restauration.

Conclusion : La Cyber-Résilience est la Nouvelle Conformité

La Directive NIS 2 et la certification HDS marquent un tournant historique pour la cybersécurité des établissements de santé en France. L'ère de la conformité basée sur des documents et des déclarations d'intention est révolue. Désormais, **l'établissement de santé doit prouver sa cyber-résilience par l'efficacité mesurable de ses moyens techniques de récupération**. C'est une transformation profonde de la culture et de la stratégie IT hospitalière.

1

Évaluer

Cartographier les systèmes critiques, auditer les sauvegardes existantes et mesurer les écarts avec NIS 2 et HDS.

2

Structurer

Réviser le PSSI, formaliser les PRA/PCA avec des RTO/RPO définis et sélectionner des prestataires certifiés HDS.

3

Sécuriser

Déployer des solutions de sauvegarde immuables, isolées et traçables, répondant simultanément à NIS 2 et HDS.

4

Valider

Automatiser les tests de récupération, documenter les résultats et préparer les preuves pour les audits ANSSI et CNIL.

Avec l'arrivée prochaine du cadre européen EHDS, ces exigences vont s'intensifier et s'harmoniser à l'échelle de l'Union Européenne. Investir dès aujourd'hui dans des solutions de sauvegarde modernes — capables de garantir **immuabilité, interopérabilité et traçabilité** — n'est pas seulement une réponse aux contraintes actuelles : c'est une anticipation stratégique des standards de demain. En faisant de leur stratégie de protection des données un atout compétitif et de conformité, les établissements de santé transforment une contrainte réglementaire en levier de confiance, de qualité des soins et de résilience durable.

🛡️ Éviter les sanctions

CNIL, ANSSI — amendes et injonctions évitées grâce à une conformité technique démontrable.

🏥 Garantir les soins

Continuité des services médicaux même en situation de crise cyber majeure.

🚀 Préparer le futur

Intégration anticipée du EHDS et positionnement dans l'espace européen de données de santé.